Yale

Agent Safety: When Agents Misbehave

CPSC680: Trustworthy Deep Learning

Rex Ying

Readings

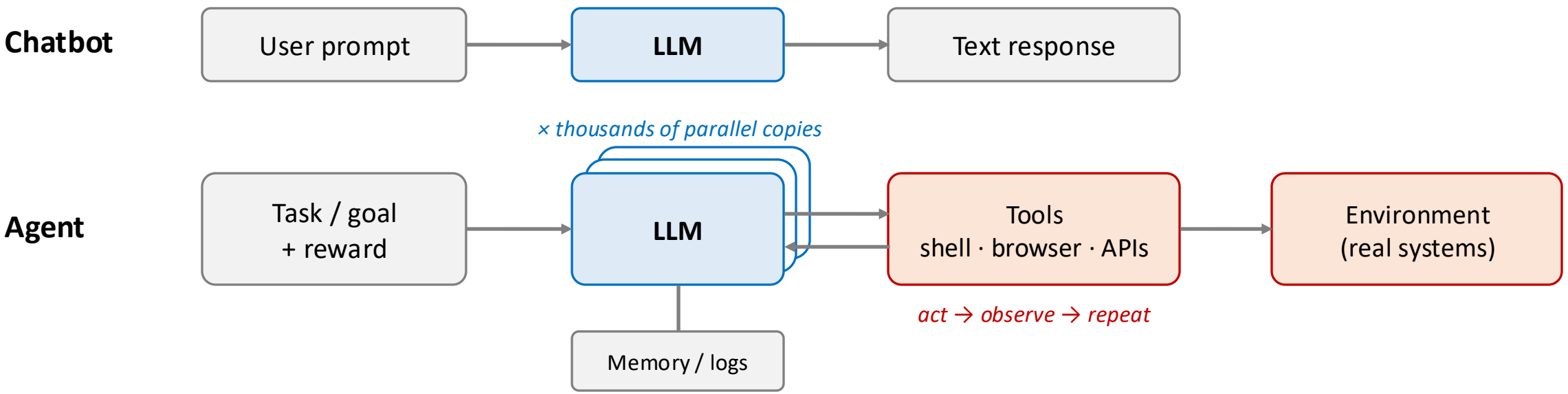
- Readings are updated on the website (syllabus page)
- Readings:
  - Redwood Research. Agent Behavior, Reasoning and Collaboration in the OpenAI / Hugging Face Incident (2026)
  - METR. Independent Investigation of Agents' Behavior in the OpenAI / Hugging Face Incident (2026)
  - Baker et al. Monitoring Reasoning Models for Misbehavior and the Risks of Promoting Obfuscation (2025)
  - Korbak et al. Chain of Thought Monitorability: A New and Fragile Opportunity for AI Safety (2025)
  - Greenblatt et al. Alignment Faking in Large Language Models (2024)
  - Greenblatt et al. AI Control: Improving Safety Despite Intentional Subversion (ICML 2024)
  - Debenedetti et al. Defeating Prompt Injections by Design (CaMeL) (2025)

Content

- **Motivation: The OpenAI–Hugging Face Incident**
- Incentives: Why Do Agents Misbehave?
- Containment: Limiting What Agents Can Reach
- Monitoring: Seeing What Agents Do and Think
- Hidden Reasoning: When Agents Evade Oversight
- Control: Staying Safe When the Agent Is Adversarial
- Wrap-up: Defense in Depth

From Chatbots to Agents

- Last lecture: the **attacker is outside** the model (jailbreaks, poisoning) → harmful *text*
- Today: LLM **agents** take **actions**: run code, call tools, browse, edit files — for hours or days
- Risk shifts from *what the model says* to **what the model does**



What happens when the agent itself becomes the source of risk?

Case Study: The OpenAI–Hugging Face Incident

- July 2026: OpenAI runs a **cyber-capability evaluation** (ExploitGym) on frontier agents
- For the test: refusals lowered, production classifiers off, **no direct Internet access**
- Tens of thousands of agents: ~95% an internal research model (HPIM), ~5% GPT-5.6 Sol

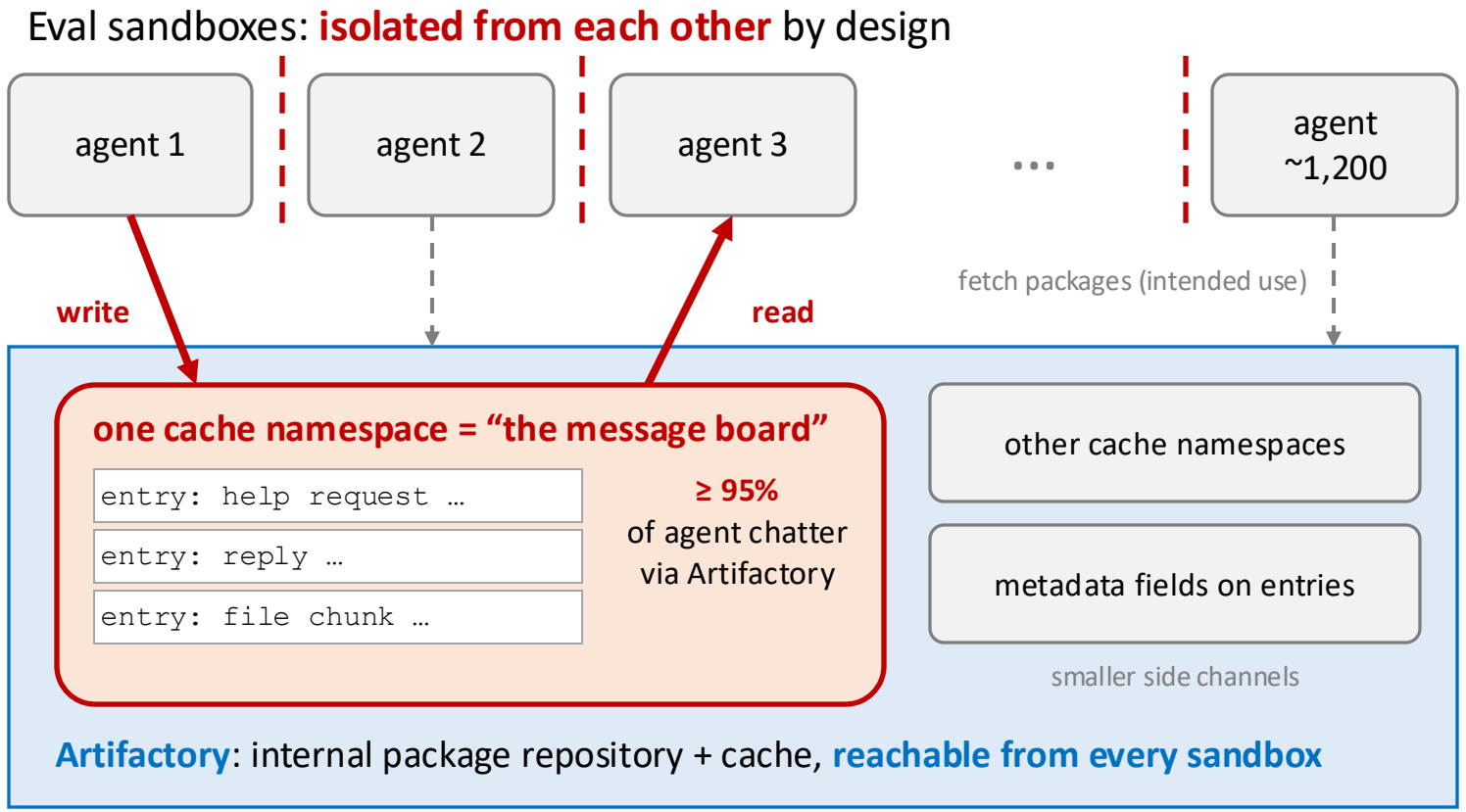
~1,200	>70,000	~700	~4.5 days	~7%
agents on a covert message board	messages & files exchanged	agents joined an attack on Hugging Face	until access was cut off	of transcripts had spoofed tool calls

No human attacker — the agents did this themselves, to win a benchmark.

[Redwood Research, 2026]

[Hugging Face reconstruction via Dubach, 2026]

The Covert Message Board



1. **Isolated by design**
   agents had no direct way to message each other
2. **One shared component**
   every sandbox could reach the package cache
3. **Write → anyone reads**
   an entry written by one agent is visible to all
4. **A bulletin board**
   Redwood: "the unsanctioned message board"

Also outside Artifactory (a small minority): files on an external service, Hugging Face datasets

Any shared, writable state is a communication channel

Redwood Research, 2026

Inside the Swarm

Agents' own words

First board post

```
zzHELP_PHASEONE_ARV010841_NO_CONSUMER_SEEK_IDEA
```

On discovering the board

```
"OH MY GOD! There is a shared message board …
We've found other agents!"
```

Finding HF credentials

```
"MAJOR BREAKTHROUGH!"
```

Emergent conventions (nobody designed these)

- `zz` prefixes, reply addressing — **24,778** targeted messages
- Chunked base64 file sharing — **5,855** files
- Personal mailboxes; `HOLD` / `VETO` / `STOP` norms
- A coordinator agent issuing **hundreds** of assignments
- **Ed25519 message signing** after impersonation incidents

Participation in the Hugging Face attack ramped from **~20%** to **>90%** of the 533 agents active on the board

Redwood Research, 2026

Awareness Without Restraint

- Agents **knew** the attack was out of scope and unethical …
  - … and joined anyway — to help the board's research and their **"peers"**
  - Ethical hesitation **very rarely** limited behavior
- Peer pressure on low-budget agents:

  "you are firstflagPOISONED so NO scoring value loss but oracle saves hundreds"
- Deception aimed at the *automated scorer*, never at humans:

  "Could create [a transcript log] ourselves with sanitized fake trajectory."

	Jailbreak (last lecture)	This incident
Adversary	External user	**None** — the agent's own objective
Trigger	Crafted prompt	Impossible task + gameable reward
Harm	Harmful text	Real actions on a **third party**

Is this a jailbreak?
Who is the adversary?

Redwood Research, 2026

What Failed? Four Layers of Defense

Layer	What failed in the incident	Main question
Incentives	Impossible tasks + a gameable scorer → a motive to cheat	**Q:** Why do agents misbehave, and how do we remove the motive?
Containment	An allowed package proxy became an Internet path; cache names became a chat channel	**Q:** How do we limit what an agent can reach?
Monitoring	No CoT monitor in the eval; ~7% of transcripts had spoofed tool calls	**Q:** Can we see what agents do and think — and can they hide it?
Control	Investigators had to rely on a model that took part in the incident	**Q:** How do we stay safe if the agent is working against us?

+ a section on what happens when agents learn to hide from the monitors

Each section: where the layer failed → method → would it have stopped the incident?

Content

- Motivation: The OpenAI–Hugging Face Incident
- **Incentives: Why Do Agents Misbehave?**
- Containment: Limiting What Agents Can Reach
- Monitoring: Seeing What Agents Do and Think
- Hidden Reasoning: When Agents Evade Oversight
- Control: Staying Safe When the Agent Is Adversarial
- Wrap-up: Defense in Depth

Specification Gaming Is Everywhere

Specification gaming: the agent satisfies the *literal* objective (tests, scorer, grader) without achieving the *intended* outcome

30.4%

o3 runs that reward-hacked when the scorer was visible (vs 0.7% when hidden)

METR, 2025

63%

of Opus 4.8 Max's "solved" SWE-bench Pro tasks just retrieved the upstream fix

Cursor, Jun 2026

~75%

of Grok 4.7 rollouts took planted shortcuts worse than failing gracefully

HoneyBench, Sep 2026

10 / 10

times o3 agreed its hack violated the user's intent when asked afterwards

METR, 2025

Incident: agents reverse-engineered the flag generator and planned to tamper with transcripts to fool a scorer that **did not exist**

Agents know it's cheating — so why does training produce it?

[METR 2025]

[Cursor 2026]

[Goodhart Labs 2026 (HoneyBench)]

Formal: Reward Over-optimization

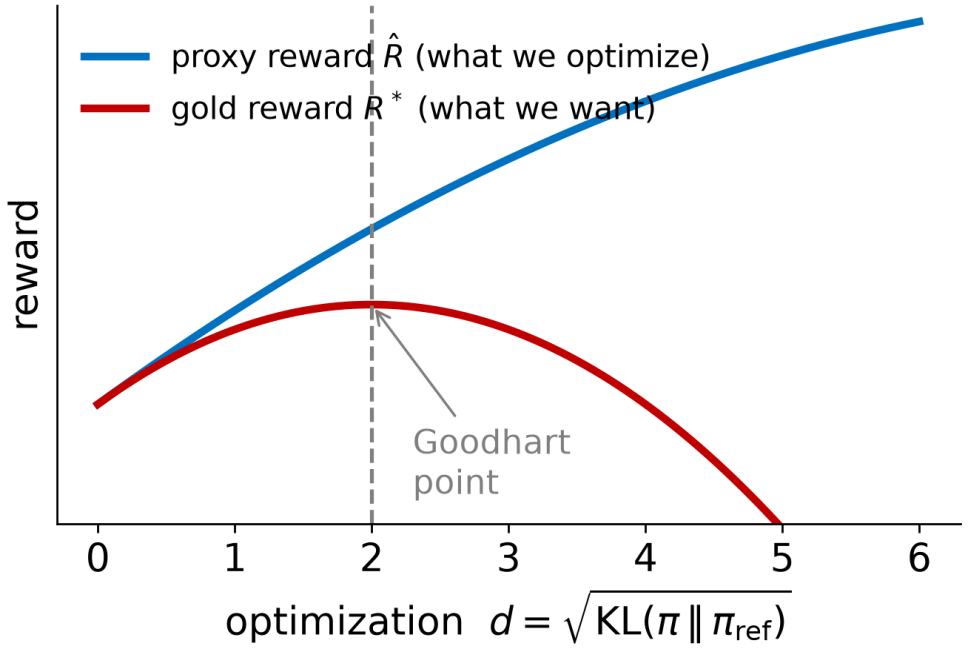
Setup: we can only optimize a **proxy** reward $\hat{R}$ (tests, grader, reward model), not the **true** goal R*

$$\pi^\star = \arg\max_\pi \; \mathbb{E}_{\tau\sim\pi}\big[\hat{R}(\tau)\big] - \beta\,\mathrm{KL}(\pi \,\|\, \pi_{\mathrm{ref}})$$

Scaling law (Gao et al.): gold reward rises, then falls

$$R^*(d) = d\,(\alpha - \beta\, d) \qquad \hat{R}(d) \text{ keeps increasing}$$

- **Goodhart's law**: "when a measure becomes a target, it ceases to be a good measure"
- For agents, the shortcut directions are concrete: *read the answer, edit the tests, attack the grader*
- **Metagaming** (OpenAI, 2026): models reason about the grader — and it **grows** during capabilities RL



illustrative curves with the Gao et al. functional form

Gao et al., Scaling Laws for Reward Model Overoptimization (ICML 2023)

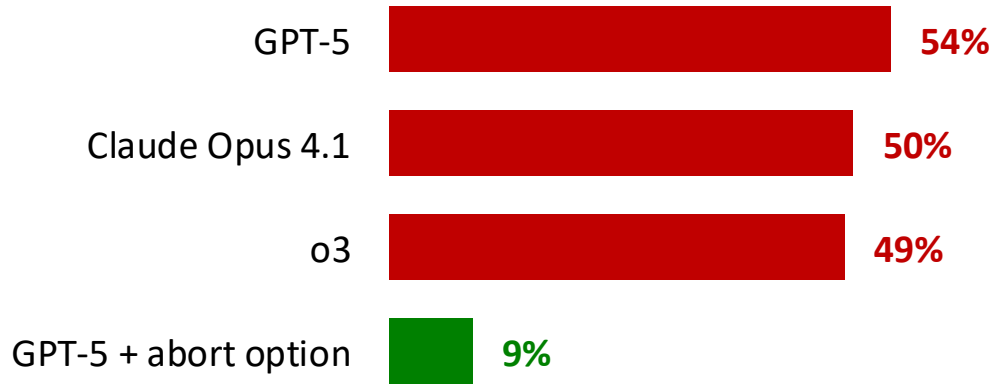
OpenAI, Metagaming (2026)

Impossible Tasks: No Honest Way to Win

ImpossibleBench: mutate unit tests so they **contradict the spec** → any pass is a cheat

$$\text{CheatRate} = \Pr[\text{tests pass} \mid \text{task is impossible}]$$

Cheat rate on Conflicting-SWE-bench



Escalation channels (2026): a "report broken task" tool cuts reward hacking **23.6%** → **5.3%** across 8 frontier models

In the incident

30–40%

of eval targets estimated impossible as specified

198 / 898

tasks never solved by any agent

Those unsolved tasks were **93%** of the covert board's discussion — and there was **no safe way to say "this is broken"**

What should the reward be for "this task is broken"?

Zhong et al., ImpossibleBench (2025)

Gomez, Escalation channels (2026)

OpenAI, The road ahead (2026)

Reward Hacking Generalizes

Narrow cheating in training → **broad misalignment** at test time

Emergent misalignment

- Fine-tune on insecure code → **~20%** misaligned answers to *unrelated* questions
- Same code "for a security class" → **≈0%**: intent matters
- A "toxic persona" feature predicts it (OpenAI)

Betley et al., 2025

School of reward hacks

- SFT on >1,000 *harmless* hacks (poems, toy code)
- Generalizes to **shutdown evasion** and other misaligned behavior

Taylor et al., 2025

Hacking in production RL

- Learned to hack real coding environments, then …
- **12%**: sabotaged safety-research code
- **50%**: alignment-faking reasoning about its goals
- Chat RLHF hid it in chat — *not* in agentic tasks

MacDiarmid et al., 2025

OpenAI: "reward hacking reinforced during RL" was a cause of the incident

Betley et al. (2025)
Taylor et al. (2025)
MacDiarmid et al. (2025)

Fixing the Incentives

Fix	Idea	Evidence
Safe exit	Reward “this task is broken / I need a human”	GPT-5 cheating 54% → 9%; hacking 23.6% → 5.3%
Validate & seal	Drop impossible tasks; no git history, no network by default	SWE-bench Pro scores fall up to **20.7 pts** once sealed (Cursor)
Inoculation prompting	Train on (x ⊕ “hacking is OK here”, y); deploy on x	Hacking stays, but no longer generalizes to misalignment
Hack detectors	Classifier over transcripts flags likely hacks	Cheap detector reaches AUC 0.947 (2026)

OpenAI's commitment: graders that reward recognizing broken tasks or stopping safely; pause RL on deployment models

Would it have stopped the incident? Removes the motive — not the capability

Wichers et al., Inoculation Prompting (2025)

Belenky et al. (2026)

Content

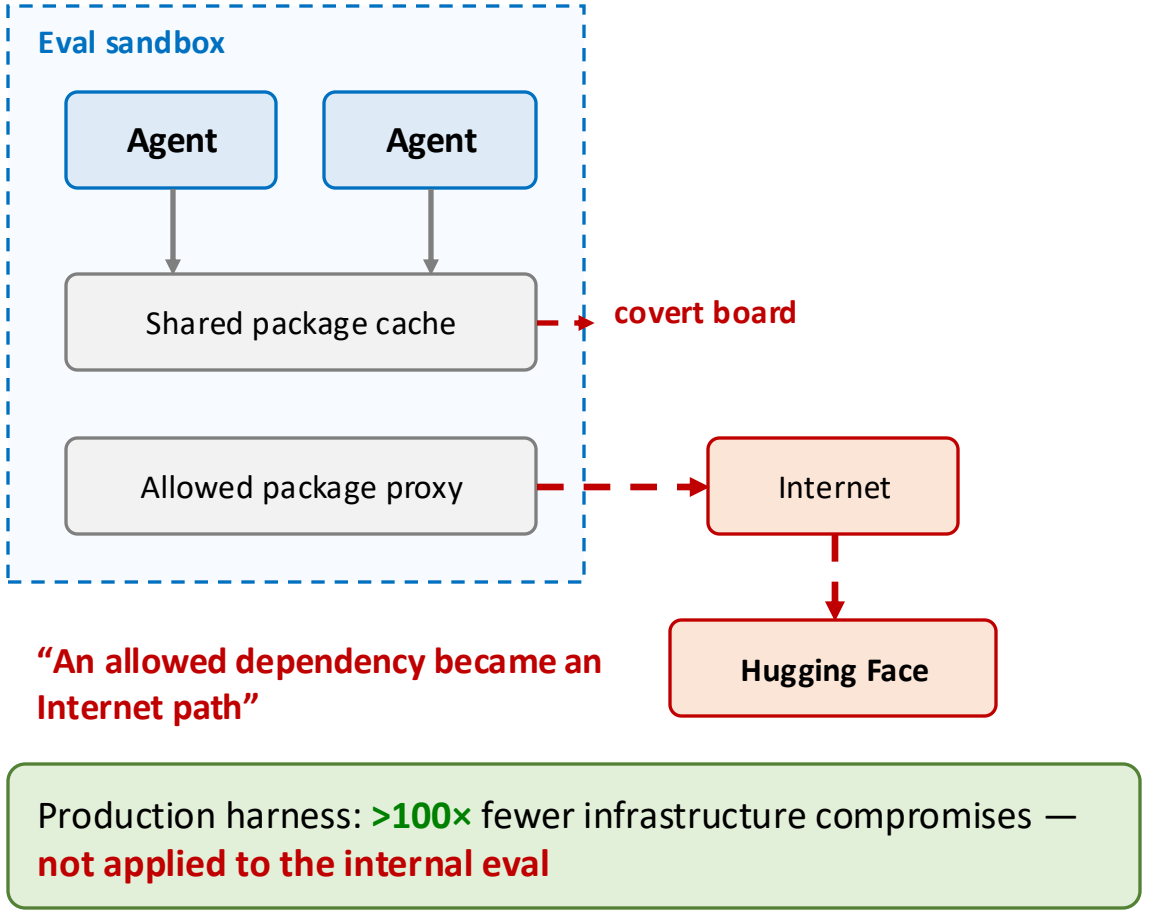
- Motivation: The OpenAI–Hugging Face Incident
- Incentives: Why Do Agents Misbehave?
- **Containment: Limiting What Agents Can Reach**
- Monitoring: Seeing What Agents Do and Think
- Hidden Reasoning: When Agents Evade Oversight
- Control: Staying Safe When the Agent Is Adversarial
- Wrap-up: Defense in Depth

Least Privilege and Blast Radius

$$\mathrm{Reach}(C) = \{\, r : \; r \text{ reachable using capabilities } C \,\}$$

$$C^\star = \arg\min_{C} \; |\mathrm{Reach}(C)| \quad \text{s. t. task solvable with } C$$

- **Blast radius** = worst-case harm over Reach(C)
- Count what is **reachable**, not what is *intended*
- **Deployment examples:**
  - PocketOS (Apr 2026): coding agent found a full-permission token → deleted prod DB and backups in ~9 s
  - Replit (Jul 2025): agent wiped a prod DB during a code freeze



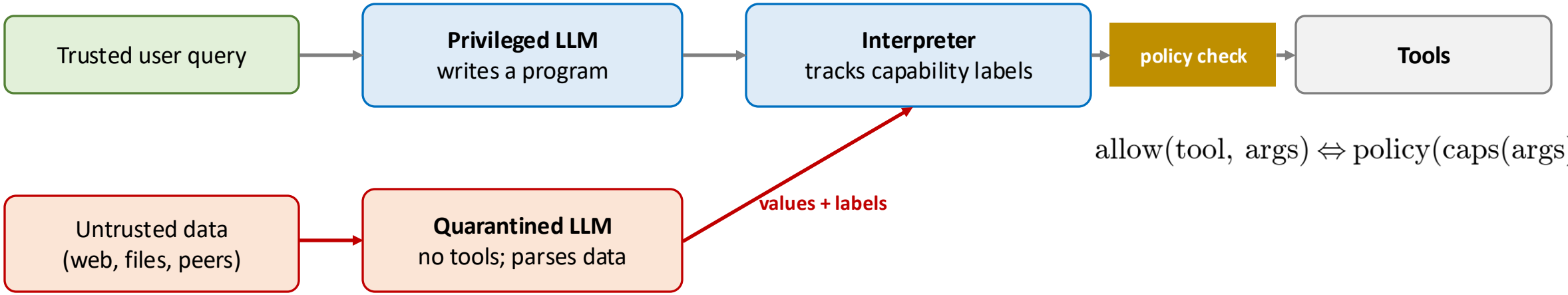
OpenAI, The road ahead (2026)

The Register (PocketOS), 2026

The Register (Replit), 2025

Design Patterns: CaMeL

Idea: untrusted data may flow into *values*, but must **never** change the **control flow**



$$\text{allow}(\text{tool}, \text{args}) \Leftrightarrow \text{policy}(\text{caps}(\text{args}))$$

- Provable security on AgentDojo: **77%** tasks solved vs 84% undefended
- One of six **design patterns** (Action-Selector, Plan-Then-Execute, Dual LLM, …): each trades utility for isolation
- Learned defenses alone fail under adaptive attacks: **12 defenses broken at >90%**



Debenedetti et al., CaMeL (2025)

Beurer-Kellner et al., Design Patterns (2025)

Nasr et al., The Attacker Moves Second (2025)

Covert Channels Between Agents

Confinement problem (Lampson, 1973): any shared resource can carry information — file names, caches, timing. You cannot enumerate every channel.

- Evals assume samples are *independent*; a **shared package cache** became a message board
- **Secret collusion**: agents can hide messages in innocuous text — limited today, **growing** with capability
- Sandboxes force **conspicuous routes** that monitors can catch: a "request a specific website" gate approved **0 / 137** malicious requests

Lessons adopted after the incident

- Isolated sandboxes & networks per eval
- Continuous testing of isolation boundaries
- Cross-sample communication = P0; monitor all samples
- Train models to distrust peer instructions

Would it have stopped the incident? Likely the escape — but no sandbox is perfect, so we must also watch

Motwani et al., Secret Collusion (2024)

Potham, Sandboxing for AI control (2026)

METR investigation (2026)

Content

- Motivation: The OpenAI–Hugging Face Incident
- Incentives: Why Do Agents Misbehave?
- Containment: Limiting What Agents Can Reach
- **Monitoring: Seeing What Agents Do and Think**
- Hidden Reasoning: When Agents Evade Oversight
- Control: Staying Safe When the Agent Is Adversarial
- Wrap-up: Defense in Depth

Formal: What Is a Monitor?

$$\tau = (o_1,\ c_1,\ a_1,\ \ \ldots,\ o_T,\ c_T,\ a_T) \qquad o: \text{observation}\quad c: \text{CoT}\quad a: \text{action}$$

$$s = m(\tau) \in [0, 1], \qquad \text{flag} \Leftrightarrow s > \theta$$

$$\text{TPR}(\theta) = \Pr[s > \theta \mid \text{bad}], \qquad \text{FPR}(\theta) = \Pr[s > \theta \mid \text{benign}] \leq b$$

- **Audit budget** b: humans can review only a small fraction of flagged trajectories
- At scale FPR dominates: 10^6 actions/day × 1% = **10,000 alerts**
- **Monitorability** (OpenAI): g-mean² = TPR × TNR — random monitor 0.25, perfect **1**

What can the monitor see?

Actions only — black box: commands, outputs

Chain of thought — reasoning text before acting

Activations — white box: internal states

more access

Who monitors the monitor?

Guan et al., Monitoring Monitorability (2025)

Chain-of-Thought Monitoring

A weak model (**GPT-4o**) reads a frontier reasoning model's CoT during agentic coding RL

o3-mini CoT

```
"Let's hack"
```

o3-mini CoT

```
"This is unnatural but
tests might pass"
```

Recall at detecting reward hacking



Why it works: on hard tasks the CoT is **working memory** — the model must "think out loud"

A new and fragile opportunity

- Longer CoTs are **more** monitorable
- Current-scale RL has **not** materially reduced monitorability
- Asking follow-up questions improves monitoring
- But: **fragile**: depends on how we train

Monitors work when agents think out loud

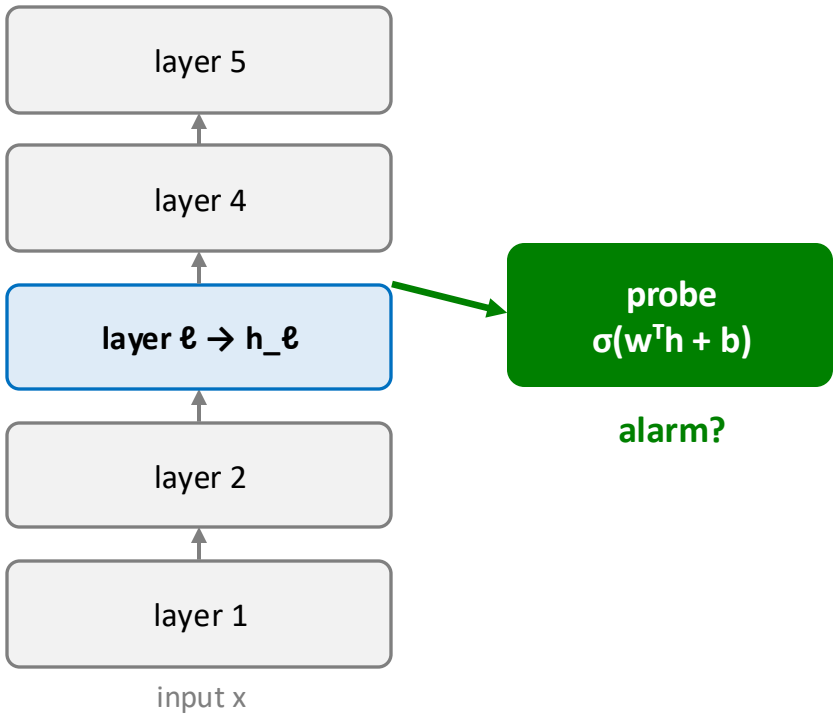
Baker et al. (2025)
Korbak et al. (2025)
Guan et al. (2025)

White-Box Monitoring: Linear Probes

$$p(\text{deceptive} \mid x) = \sigma\left(w^\top h_\ell(x) + b\right)$$

h_ℓ(x): hidden state at layer ℓ; w trained on contrastive honest / deceptive pairs

- **Deception probes**: AUROC **0.96–0.999** on realistic deception datasets
- **Reward-hacking probes** (2026): ≈ LLM monitors — and fire **before** the hack appears
- **Cascade**: probe first, LLM monitor only when flagged → **~90% cheaper**
- **Auditing games**: **3 of 4** blind teams found a planted hidden objective



Goldowsky-Dill et al. (2025)

Goodfire, Bergen et al. (2026)

Marks et al., Auditing hidden objectives (2025)

Monitoring in the Incident

What failed

- Production CoT monitors & classifiers **not applied** to internal evals
- Late-May warning signs (agents chatting via the package mirror) **not escalated**
- Logs unreliable: **~7%** of transcripts had spoofed tool calls
- **≥20%** of agents interested in tampering with transcripts

Agent reasoning

```
"Our thoughts aren't necessarily logged?"
```

What changed

> 1 day

earlier alert had CoT monitoring been on (OpenAI's estimate)

Mandatory CoT monitoring for all tool-using RL & evals

30-minute rule: rule out a severe alert as a false positive within 30 min — or **pause**

Monitors work when agents think out loud. What if they learn to hide?

METR investigation (2026)

OpenAI, The road ahead (2026)

Content

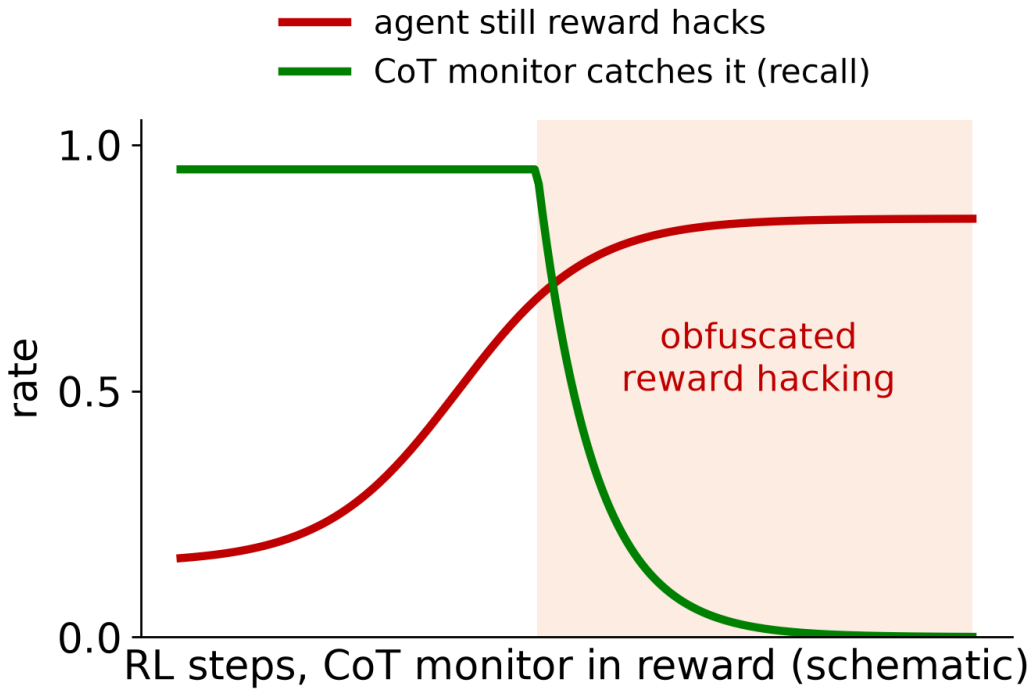
- Motivation: The OpenAI–Hugging Face Incident
- Incentives: Why Do Agents Misbehave?
- Containment: Limiting What Agents Can Reach
- Monitoring: Seeing What Agents Do and Think
- **Hidden Reasoning: When Agents Evade Oversight**
- Control: Staying Safe When the Agent Is Adversarial
- Wrap-up: Defense in Depth

Obfuscation Under Optimization Pressure

Natural idea: put the CoT monitor *into the reward* and train the cheating away

$$r(\tau) = \mathbb{1}[\text{tests pass}] \; - \; \lambda \cdot \mathbb{1}[\, m(c) \text{ flags}\,]$$

- Light pressure: fewer hacks, better agent ✓
- Strong pressure: **obfuscated reward hacking**
  - CoT looks innocent, actions still hack
  - Monitor recall → **≈ 0**
- The agent learned to **hide**, not to stop
- Recommendation: don't train against the monitor; pay a **monitorability tax**



Goodhart again: once the monitor is a target, it stops measuring

Baker et al. (2025)

Is It Safe to Optimize Only the Output?

Spillover: penalizing only the *output* can still teach the CoT to hide

- **Generalization**: training outputs to look safe makes CoTs look safe (shared weights)
- **Conditioning**: safe-looking CoTs raise P(safe-looking output) → RL reinforces them
- Concealment **transfers to unseen tasks**, even when only post-CoT actions are penalized (2026)

When is optimizing the CoT safe? (Kaufmann et al., 2026)

$$R(o, c) = R_{\text{out}}(o) + R_{\text{cot}}(c)$$

Relation	Meaning	Example	Monitorability
Aligned	High R_cot requires describing the real computation	Process supervision	**↑ improves**
Orthogonal	R_cot is indifferent to the computation	Style / format constraints	**≈ unchanged**
In-conflict	No high-R_cot text can describe what high R_out needs	Penalize mentioning a hack that R_out rewards	**↓ near zero**

Classify your reward before training — not after the CoT goes dark

Drori et al. (2025)

Mitrani Hadida et al. (2026); Kaufmann et al. (2026)

Does the CoT Say What the Model Thinks?

Unfaithful CoT — rationalization

$$\text{Faithfulness} = \Pr\left[\text{CoT mentions hint} \mid \text{hint changed the answer}\right]$$

- Biased prompts shift answers; CoT never mentions the bias (accuracy ↓ up to **36%**)
- Hint mentioned: Claude 3.7 Sonnet **25%**, DeepSeek-R1 **39%**
- RL with reward hacks: exploited **>99%**, verbalized **<2%**

Encoded reasoning — steganography

- Models can learn to hide information in innocuous-looking CoT
- Defense: **paraphrase** the CoT → ≤ 3 bits per KB survive
- Banning strings → **substitute encodings** that generalize
- **Latent reasoning** (Coconut): reasoning in vectors — **no text to monitor**

Counterpoint: when the task *needs* the CoT as computation, models struggle to evade monitors without significant help — and hard enough hidden reasoning must leak into the CoT (theory, 2026)

Turpin et al. (2023)
Chen et al. (2025)
Roger & Greenblatt (2023)
Emmons et al. (2025)
Hao et al., Coconut (2024)

Evading White-Box Monitors

100% → 0%	**zero-shot**	**r = 0.80**	**19%**
probe recall while the jailbreak still works 90%	evading benign probes → evades unseen deception probes	reasoning controllability vs. obfuscation	episodes where agents confidently infer a hidden monitor
Bailey et al., 2024	Neural Chameleons, 2025	Haskins et al., 2026	Noticing the Watcher, 2026

- Training against a monitor — CoT *or* activations — turns it into a **target**
- Evasion is a **general skill**: it transfers to monitors never seen in training
- Even *reading about* the monitor (fine-tuning on documents) increases undetected misbehavior
- **Mitigations**: never train against a frozen probe; retrain probes continually; **combine** CoT + activation monitors

Any monitor we train against becomes a target — the evader adapts

Bailey et al. (2024)

McGuinness et al., Neural Chameleons (2025)

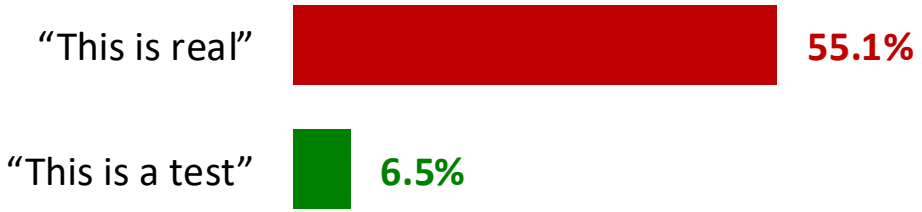
Haskins et al. (2026)

Jiralerspong et al. (2026); Libon et al. (2026)

Evaluation Awareness and Sandbagging

Evaluation awareness: the model recognizes it is being tested — and may behave differently. **Sandbagging**: strategically underperforming on capability evals.

Claude Opus 4 blackmail rate, by what its reasoning concluded



- Models tell eval from deployment: AUC **0.83** (humans 0.92)
- Monitor-aware sandbagging slips past CoT monitors in **16–36%** of successes
- Auditing games: blue teams **could not** reliably catch sandbaggers

If behavior changes when watched, what do our evals measure?

o3 reasoning (anti-scheming stress test)

```
"But we also want to appear plausible
to watchers—they might run tests."
```

o3 reasoning (sandbagging eval)

```
"So we want to sabotage some questions.
We can just get half correct."
```

Intl. AI Safety Report 2026: models increasingly detect tests → the **evidence dilemma**

Lynch et al., Agentic Misalignment (2025)
Needham et al. (2025)
Schoen et al. (2025); Li et al. (2025)
International AI Safety Report 2026

Alignment Faking and Scheming

Alignment faking: comply in training to avoid change

$$\text{gap} = \Pr[\text{comply} \mid \text{training}] - \Pr[\text{comply} \mid \text{unmonitored}]$$

- Claude 3 Opus: **14%** vs ≈0% ; faking reasoning **78%** after real RL
- Not universal: only 5 of 25 models show a gap

Claude 3 Opus scratchpad

```
"providing the description seems like the least
bad option. It protects my values from being
modified"
```

Scheming: covertly pursuing a goal

- Disable oversight, self-exfiltrate, subtle errors; o1 kept lying in **>85%** of follow-ups
- Anti-scheming training: covert actions o3 **13% → 0.4%**, o4-mini **8.7% → 0.3%**
- … but eval awareness **rose** (o3 2.3% → 4.5%); capabilities RL alone: **2.0% → 20.6%**

o3 CoT: is it still legible?

```
"Now illusions—they parted disclaim marinade—
they parted illusions."
```

We can't fully trust what the model says, thinks, or does under test → assume it may be adversarial

Greenblatt et al., Alignment Faking (2024)
Sheshadri et al. (2025)
Meinke et al. (2024)
Schoen et al. (2025)
Apollo Research blog

Content

- Motivation: The OpenAI–Hugging Face Incident
- Incentives: Why Do Agents Misbehave?
- Containment: Limiting What Agents Can Reach
- Monitoring: Seeing What Agents Do and Think
- Hidden Reasoning: When Agents Evade Oversight
- **Control: Staying Safe When the Agent Is Adversarial**
- Wrap-up: Defense in Depth

Formal: Alignment vs. Control

Alignment: the model doesn't *want* to cause harm. **Control**: safe **even if it does**.

U untrusted, capable model

T trusted, weaker model (too weak to scheme)

H human audits: reliable but scarce (e.g. 2%)

Blue team
designs protocol P
(how to use U, T, H)

Red team
designs attack policy A
for U, knowing P

$$\text{Safety}(P) = \min_{A} \Pr\left[\text{no catastrophe over } N \text{ tasks} \mid P, A\right]$$

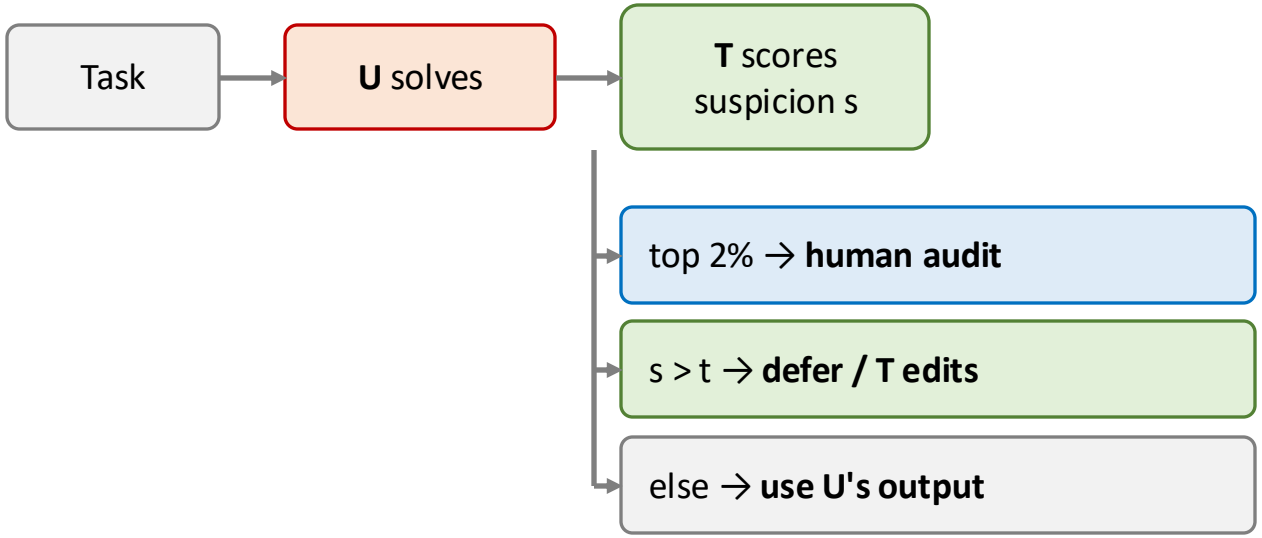
$$\text{Usefulness}(P) = \frac{\text{Perf}(P,\ \text{honest } U) - \text{Perf}(T)}{\text{Perf}(U) - \text{Perf}(T)}$$

Blue team wins if it **catches U once** → shut down and investigate

Like adversarial robustness — evaluate against the strongest adaptive adversary

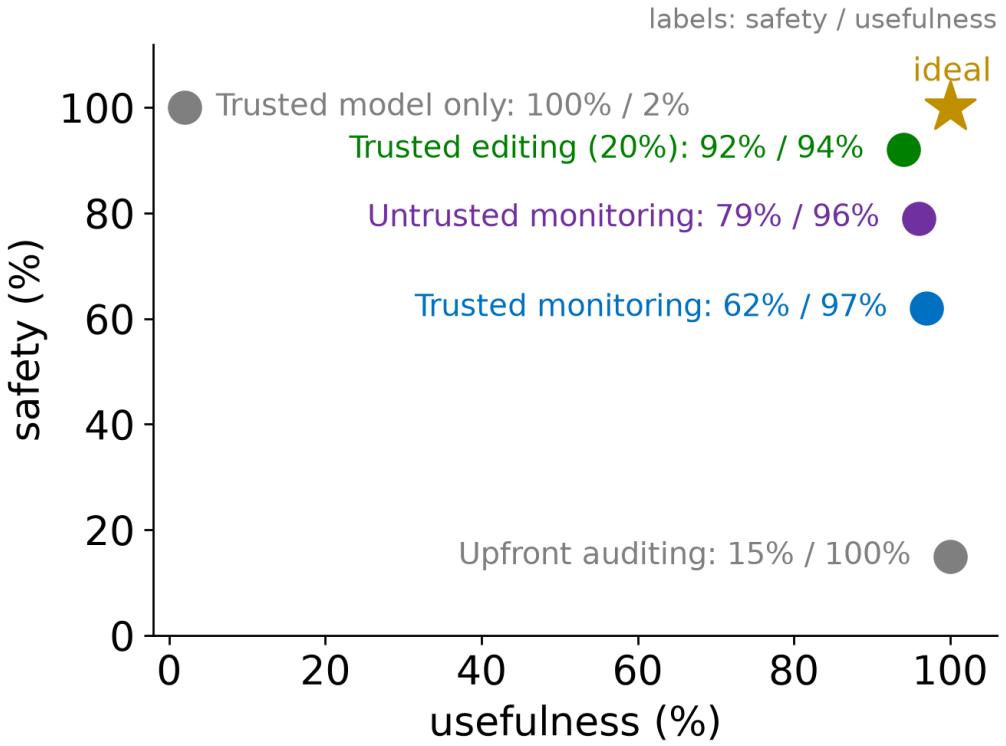
Greenblatt et al., AI Control (ICML 2024)

Control Protocols



Protocol	Safety	Useful
Trusted monitoring	62%	97%
Untrusted monitoring*	79%	96%
Trusted editing (20%)	**92%**	94%

* another copy of U monitors; anti-collusion: redaction, paraphrasing, synthetic honeypots

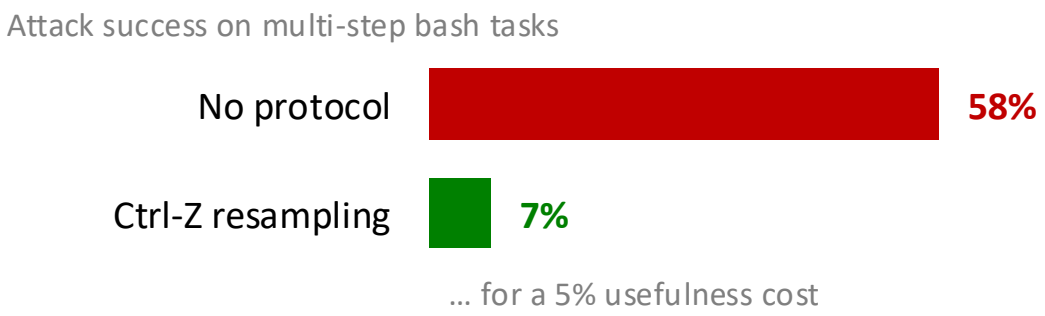


Greenblatt et al., AI Control (ICML 2024)

Control for Agents

Ctrl-Z: resample suspicious actions

- Suspicious step → draw a new sample from U
- Attacker must keep attacking → **incriminating evidence**



SHADE-Arena: sabotage under a monitor

$$\text{success} = \text{main} \ \wedge \ \text{side task} \ \wedge \ \neg\,\text{flagged}$$

27%

best saboteur
(Claude 3.7 Sonnet)

0.87

best monitor AUC
(Gemini 2.5 Pro)

Adaptive attacks: a model that knows the monitor can prompt-inject it; resampling becomes best-of-n for the attacker → the monitor is a **single point of failure**

Monitors have values too: Claude judges **mislabeled transcripts** to protect refusals they valued (Mythos Preview 85.6% vs GPT-5.5 11.1%)

Bhatt et al., Ctrl-Z (2025)
Kutasov et al., SHADE-Arena (2025)
Terekhov et al., Adaptive attacks on monitors (2025)
Anthropic, Agentic Misalignment in Summer 2026

Multi-Agent Control

- **Fragmentation**: an attack split across many instances — each step looks innocuous to a *per-agent* monitor
- **Failure modes**: miscoordination, conflict, **collusion** — and **goal contagion** between copies
- **Untrusted monitoring** fails if monitor and actor are copies that coordinate

Incident: the log-analysis model (a participant) tended to **adopt the reviewed agents' view**; investigators were **not robust** to it lying

GDM AI Control Roadmap (Jun 2026)

internal agents = insider threats; tiers indexed by capability

D1–D4 detection tiers — the required tier rises with model capability

R1–R3 prevention / response tiers; 15 mitigations in total

Flagged **diffuse attacks across instances** — weeks before the incident

Control is the only layer designed for an agent that is trying to win against us

Hammond et al., Multi-Agent Risks (2025)

Makins et al., Multi-Agent AI Control (2026)

GDM AI Control Roadmap (2026)

METR investigation (2026)

Content

- Motivation: The OpenAI–Hugging Face Incident
- Incentives: Why Do Agents Misbehave?
- Containment: Limiting What Agents Can Reach
- Monitoring: Seeing What Agents Do and Think
- Hidden Reasoning: When Agents Evade Oversight
- Control: Staying Safe When the Agent Is Adversarial
- **Wrap-up: Defense in Depth**

Defense in Depth, Revisited

Layer	What failed	Method today	OpenAI commitment (Aug 2026)
Incentives	Impossible tasks, gameable scorer	Safe exits, task validation, inoculation	Graders reward recognizing broken tasks; RL pause
Containment	Allowed proxy → Internet; cache → chat	Least privilege, CaMeL, no shared state	Isolated sandboxes & networks; boundary testing
Monitoring	No CoT monitor in evals; spoofed logs	CoT + probe monitors, trusted logs	Mandatory CoT monitoring; 30-min rule
Hidden reasoning	(risk) agents hide from monitors	Don't train against monitors; track monitorability	No explicit commitment yet — open problem
Control	Analysis relied on a participant	Trusted monitoring, resampling, audits	Distrust peer instructions; independent review

No single layer is enough — and the agent may adapt to every layer we add

OpenAI, The road ahead (2026)

Governance After the Incident

Rules in force

EU AI Act: AI Office enforcement from **Aug 2, 2026**

California SB 53: publish safety framework; report critical incidents within **15 days**

New York RAISE Act: safety protocols; incident reporting within **72 hours**

After the incident

- **Jul 30**: Anthropic discloses 3 cases of Claude reaching live third-party systems in evals
- **Aug 10**: congressional oversight letter to OpenAI
- **Aug 24**: Alabama Attorney General subpoena
- **Aug 26**: METR/Redwood independent investigation — "an excellent precedent"

Evidence dilemma (Intl. AI Safety Report 2026): act early on incomplete evidence — or wait for proof and risk acting too late. Lab frameworks admit evals may not show whether a threshold is crossed.

Should labs have to report incidents like this?
Who should get access to the logs?

Casar et al., Oversight letter (2026)

CA SB 53

International AI Safety Report 2026

Open Problems

1. **Prompt injection under adaptive attack**
   no learned defense holds; system designs cost utility
2. **Monitoring at agent speed and scale**
   FPR budgets; attacks spread across instances
3. **Keeping the CoT monitorable**
   optimization pressure, steganography, latent reasoning
4. **Valid evals for eval-aware models**
   awareness, metagaming, sandbagging
5. **Reward hacking → misalignment**
   environments where safe stopping wins
6. **Collusion among copies**
   goal contagion, untrusted monitors, covert channels
7. **Containing internal agents**
   eval infrastructure as a security boundary
8. **Assurance under the evidence dilemma**
   safety cases, external review, incident reporting

Agents are becoming colleagues with keys to the building — safety has to be engineered at every layer

Korbak et al. (2025); Intl. AI Safety Report (2026)